

SCENARIO - BASED ASSESSMENT

1. Footprinting Tools - Conducting Competitive Intelligence.

Aim:

To perform a passive security assessment of ABC Technologies using footprinting tools without directly interacting with the company's server.

Introduction:

Footprinting is the process of collecting publicly available information about a target organization. Passive footprinting gathers information from public sources without sending traffic to the target systems, making it useful for competitive intelligence and security assessments.

Tools used

WHOIS

Harvester

Netcraft

DNS Dumpster.

Application

1. WHOIS

eg: Command

whois abc technologies.com

Information Collected.

⇒ Domain register date

⇒ Expiry date

⇒ Registrar details

⇒ Name server.

⇒ Identity domain ownership.

⇒ Reveals domain lifecycle information.

2. Harvester

eg: Command

theHarvester -d abctechnologies.com -b all

Information Collected

⇒ Employee email address

⇒ Public subdomains

⇒ Hostnames

⇒ IP address

⇒ Support security.

3. Netcraft

Website

<https://www.netcraft.com/>

Information Collected

⇒ Web server

⇒ Operating system

⇒ Tech stack

⇒ Host provider

4. DNS Dumpster

⇒ Public subdomains

⇒ DNS records

⇒ Mail servers

⇒ Host IP address.

Conclusion

Passive footprinting helps security professionals gather valuable public information without directly interacting with target system.

2. DNS Zone Transfers.

Aim:

To verify whether a DNS server allows DNS Zone (AXFR).

Introduction:

A DNS Zone Transfer copies DNS records from a primary DNS server to secondary server.

Using Dig:

```
dig AXFR example.com @ns1.example.com
```

⇒ Internal hostnames

⇒ Public subdomains

⇒ MX records

⇒ Name servers

⇒ DNS records

Security Implications:

The exposed information help attackers:

⇒ Map organization

⇒ Identify system

⇒ Local mail servers

⇒ Discover hidden subdomains

⇒ Plan targeted attacks.

Recommendations

⇒ Disable unauthorized zone transfers.

⇒ Allow AXFR only for trusted secondary DNS.

⇒ Local mail servers.

⇒ Discover hidden subdomains.

⇒ Plan targeted attacks.

⇒ Monitor DNS logs.

⇒ Use firewalls.

Conclusion

Restricting DNS zone transfers prevents attackers from collecting valuable security.

3) Social Engineering Attacks and Countermeasures.

How It works.

1. The attacker send a fake email.

2. Email appears to come from IT dept.

3. Employees click the links.

4. They enter usernames & pass.

5. Attacker steals credentials.

Countermeasures

1. Verify the Sender
Check the sender's email address carefully before responding.
 2. Avoid clicking Suspicious links
However links to inspect the destination URL before clicking.
 3. Verify Through Official Channels
Contact the IT department directly if the request seems unusual.
 4. Check for Warning Signs
Look for spelling mistakes, urgent language, and unusual request.
 5. Enable Multi-Factor Authentication (MFA)
Even if credentials are stolen, MFA provides layer.
 6. Report Suspicious Emails
Notify the organization's IT or security team immediately.
 7. Keep Security Awareness Updated
Participate in regular cybersecurity.
- ⇒ Verify sender prevents trust in emails.
 - ⇒ Inspecting links helps identify fake websites.
 - ⇒ MFA blocks unauthorised access.
 - ⇒ Reporting suspicious emails helps protect.